# BCP Voorbereiding Billy Bonka

**Bedrijfsnaam:** Billy Bonka B.V.
**Sector:** Voedsel- en zoetwarenindustrie (chocoladeproductie)
**Locatie:** Aan de rand van Eindhoven
**Aantal medewerkers:** In totaal ongeveer 250 medewerkers (waarvan circa 50 kantoormedewerkers en 10 vrachtwagenchauffeurs)
**Kernactiviteiten:** Het produceren van chocolade voor de Nederlandse en Europese markt, gebaseerd op een speciaal geheim recept. De activiteiten omvatten productie, kwaliteitscontrole, logistiek en distributie.

# 1.1 Kritieke processen

## 1. Operationele Productie (OT - Operationele Technologie)

De kern van de fabriek draait om de productielijnen (Lijn 1 t/m Lijn 12). Verstoring van deze systemen legt direct de omzet van €200 miljoen per jaar stil.

- **Smeltlijn & Gietlijn:** Aansturing via PLC's (Programmable Logic Controllers) en HMI's (Human Machine Interfaces) voor het smelten, vermalen, tempereren en gieten van chocolade.
- **Koeling:** Cruciaal voor het uitharden van het product; uitval leidt tot bederf of kwaliteitsverlies van de voorraad van €8 miljoen.
- **Centrale Sturing:** De Operator stations in de 'Centrale sturing' bedienen de productiesystemen vanaf het IT-netwerk.

## 2. Gebouwbeheer en Veiligheid

In de secties 'HVAC' en 'Brandmeld' zijn systemen te zien die de werkomgeving en veiligheid bewaken:

- **Klimaatbeheersing (HVAC):** PLC's voor opslag en magazijn zijn essentieel om de chocolade onder de juiste condities te bewaren.
- **Brandbeveiliging:** De aansturing van sprinklers en sensoren is direct verbonden met het netwerk; een cyberincident zou fysieke veiligheidssystemen kunnen uitschakelen.

## 3. Logistiek en Distributie

- **Magazijnbeheer:** De verbinding tussen de 'Logistics' afdeling en de centrale servers is nodig voor de distributie naar (inter)nationale klanten.
- **Engineering Station:** Wordt gebruikt voor onderhoud en aanpassingen aan de productiesystemen.

## 4. Informatiebeheer en Data (IT)

In het 'Datacenter' bevinden zich de meest kwetsbare digitale assets:

- **Intellectueel Eigendom (B-Disk):** Bevat het geheime chocoladerecept, de basis voor het succes van het bedrijf.
- **Personeelsgegevens (M-Disk):** Bevat gevoelige informatie over de 250+ medewerkers.
- **Authenticatie & Backup:** Essentieel voor het herstel na een incident (Incident Response).

# 2.1 Business Continuity Plan – Billy Bonka B.V.

Dit Business Continuity Plan beschrijft hoe chocoladefabriek Billy Bonka B.V. haar belangrijkste bedrijfsprocessen kan blijven uitvoeren tijdens een storing of cyberincident. De fabriek is afhankelijk van zowel IT-systemen (zoals e-mail, fileservers en de authenticatieserver) als OT-systemen (zoals de productielijnen met PLC's, de koeling en HVAC). Omdat de productie van chocolade centraal staat in het bedrijf, is het belangrijk dat storingen snel worden opgelost en dat medewerkers weten wat ze moeten doen tijdens een crisis.

Het doel van dit plan is om duidelijk te maken welke processen vitaal zijn voor de organisatie, hoe deze beschermd kunnen worden en wat er moet gebeuren als er toch een verstoring optreedt. Het plan wordt gebruikt door het crisisteam en door medewerkers die verantwoordelijk zijn voor IT, beveiliging en productie.

## Belangrijkste processen en afhankelijkheden

Binnen Billy Bonka zijn een aantal processen direct kritisch voor de continuïteit. Het belangrijkste proces is Productie & Operations. Zonder de productielijn kan er geen chocolade worden gemaakt en is er direct omzetverlies. Dit proces is afhankelijk van PLC's, HMI-schermen, de engineeringstation, de koeling en het HVAC-systeem. Als één van deze systemen uitvalt, komt de hele fabriek stil te liggen.

Daarnaast zijn Logistiek & Distributie en Orderverwerking & Klantencommunicatie belangrijke processen. Deze zorgen ervoor dat grondstoffen binnenkomen en dat geproduceerde chocolade wordt geleverd aan klanten. Bij een verstoring kunnen ordergegevens niet worden verwerkt, voorraadniveaus worden niet bijgewerkt en weten klanten niet waar hun bestelling is. Dit veroorzaakt reputatieschade en financiële schade.

Andere processen, zoals HR en de financiële administratie, zijn minder tijdkritisch. Deze kunnen tijdelijk handmatig worden uitgevoerd als de IT-systemen niet beschikbaar zijn.

## Risico's en interne zwaktes

Uit de interviews blijkt dat de organisatie een aantal zwakke plekken heeft. Medewerkers gebruiken soms gedeelde wachtwoorden, systemen worden onvoldoende gepatcht en back-ups worden niet regelmatig getest. Er is geen Multi-Factor Authenticatie (MFA) en beveiligingstrainingen worden nauwelijks gevolgd. Veel medewerkers klikken waarschuwingen op schermen weg zonder te lezen, waardoor problemen niet worden gemeld.

Ook bij de directie is beveiliging geen prioriteit. De CEO deelt wachtwoorden met zijn assistente en vindt cybersecurity vooral een kostenpost. Deze houding verhoogt het risico op datalekken, ransomware en verstoringen van de productie.

Vooral in de fabriek zijn er risico's: er draaien oude systemen zoals Windows XP en Windows Server 2012, die geen beveiligingsupdates meer krijgen. Ook de PLC's zijn verouderd. Hierdoor is de fabriek kwetsbaar voor cyberaanvallen.

## Hoe de organisatie moet reageren tijdens een incident

Wanneer zich een incident voordoet, wordt het crisisteam direct opgeroepen. De Algemeen Directeur is de crisisleider en neemt de belangrijkste beslissingen. De Manager IT is verantwoordelijk voor de technische analyse en het herstel van systemen. De Security & Privacy Officer onderzoekt of er sprake is van een datalek en onderhoudt contact met de Autoriteit Persoonsgegevens indien nodig.

Het crisisteam start altijd met het verzamelen van informatie: wat is er precies gebeurd, welke systemen zijn getroffen en welke processen liggen stil? Daarna wordt bepaald welke acties nodig zijn om verdere schade te voorkomen. Denk hierbij aan het isoleren van besmette systemen, het blokkeren van accounts of het uitschakelen van externe toegang.

Pas als de situatie onder controle is, begint het herstel. Hierbij wordt volgens een vaste volgorde gewerkt, waarbij de meest kritieke systemen als eerste worden hersteld. Voor Billy Bonka zijn dat de authenticatieserver, de koelingssystemen en de productielijnbesturing. Pas daarna komen ondersteunende systemen zoals e-mail of werkplekken aan de beurt.

## Back-ups en herstel

Back-ups spelen een belangrijke rol in de continuïteit van de fabriek. Daarom moeten alle kritieke systemen dagelijks worden geback-upt. Elke week wordt een kopie offline opgeslagen, zodat ransomware de back-ups niet kan versleutelen. Minimaal één keer per kwartaal wordt getest of de back-ups daadwerkelijk kunnen worden teruggezet.

Voor de OT-omgeving, zoals de PLC-configuraties, moeten de instellingen altijd veilig worden opgeslagen zodra er wijzigingen worden gemaakt. Als een PLC defect raakt, moet het mogelijk zijn om de productie snel opnieuw op te starten.

## Omgaan met interne dreigingen

Omdat interne fouten of nalatigheid een grote rol spelen in incidenten, moet de organisatie investeren in bewustwording. Dit betekent dat alle medewerkers elk jaar een verplichte security awareness-training volgen, inclusief oefeningen over phishing, veilig wachtwoordbeheer en omgaan met waarschuwingen.

Gedeelde accounts worden afgeschaft. Iedereen krijgt een eigen account met beperkte rechten. MFA wordt verplicht voor alle medewerkers, ook in de fabriek. Tot slot moet er een

duidelijk beleid komen dat wachtwoorden nooit gedeeld mogen worden, ook niet door de directie.

## Communicatie tijdens een crisis

Heldere communicatie voorkomt paniek en misverstanden. Daarom is vooraf afgesproken wie welke groepen informeert:

HR informeert alle medewerkers via e-mail, Teams of SMS.

De Communicatieadviseur informeert klanten en leveranciers.

De Security Officer communiceert met de Autoriteit Persoonsgegevens bij een datalek.

De Directeur communiceert indien nodig met de media.

Alle communicatie moet feitelijk en rustig zijn, en onduidelijkheid vermijden.

## Oefenen en verbeteren

Het BCP moet geen document zijn dat alleen op de plank ligt. Daarom wordt minstens één keer per jaar een table-top oefening georganiseerd waarbij een cyberincident wordt gesimuleerd. Tijdens deze oefening werkt het crisisteam het scenario door en wordt beoordeeld of iedereen zijn rol kent.

Ook de restore-procedures, de noodprocedures voor de productielijn en de communicatieprotocollen worden getest. Op basis van de evaluatie wordt het BCP aangepast en verbeterd.

## 2.2 Business Impact Analysis (BIA)

In de BIA zijn de kritieke processen en bijbehorende systemen van Billy Bonka B.V. geïdentificeerd om de impact van uitval te minimaliseren.

| Proces | Kritiek Systeem | Impact bij uitval | RTO (Hersteltijd) | RPO (Dataverlies) |
|---|---|---|---|---|
| **Productie (Smelt- & Gietlijnen)** | PLCs (S7-1200), GBS Server, Engineering Station | Stopzetting productie, bederf van grondstoffen (chocolade), omzetverlies (€8M per week). | 4 uur | N.v.t. (Real-time) |
| **Logistiek & Distributie** | Operator Stations, Centrale Sturing | Geen levering aan supermarkten, boetes voor te late levering, reputatieschade. | 8 uur | 1 uur |
| **Financiën & Administratie** | Fileshare B-Disk, Authentication Server | Onmogelijk om facturen te sturen of salarissen te betalen, verlies van geheime recepten. | 24 uur | 24 uur |
| **Koeling & Klimaatbeheersing** | HVAC, Koeling PLCs | Verlies van voorraad door onjuiste temperatuur, kwaliteitsproblemen. | 2 uur | N.v.t. |

# 3.1 Threat Model

## 1. Architectuur & Trust Boundaries

Op basis van het architectuurdiagram onderscheiden we vier kritieke zones met bijbehorende 'Trust Boundaries'.

1. **External Zone (Internet):** Onvertrouwd. Bron van aanvallen en remote vendors.
2. **Enterprise Zone (Office & Datacenter):** Semi-vertrouwd. Bevat werkplekken, fileservers en authenticatie.
3. **Industrial DMZ (Engineering Room):** Kritiek knooppunt. Bevat de Gateway, GBS Server en Engineering Stations.
4. **Manufacturing Zone (Factory Floor):** Hoogst kritiek. Bevat PLCs (S7-1200), HMIs en robots.

## 2. Bedreigingsanalyse per Component (STRIDE)

### 2.1 Asset: De Gateway (Verbinding Buitenwereld <-> Engineering)

*Locatie: Engineering Room Functie: Toegang voor externe leveranciers.*

| STRIDE Categorie | Specifieke Dreiging | Impact | Risico | Mitigatie |
|---|---|---|---|---|
| **Spoofing** | Een aanvaller doet zich voor als de leverancier (Vendor Impersonation) door zwakke authenticatie (geen MFA). | Ongeautoriseer de toegang tot het hart van de fabriek. | **Kritiek** | Implementeer VPN met MFA + IP Whitelisting. |
| **Tampering** | Man-in-the-Middle (MitM) aanval op het onversleutelde verkeer tussen leverancier en gateway. | Injecteren van malware in sessies. | **Hoog** | Verplicht IPsec of SSL VPN tunnels. |
| **Elevation of Privilege** | Misbruik van kwetsbaarheden in de | Springplank naar de PLCs. | **Hoog** | Patchmanagement en |

| STRIDE Categorie | Specifieke Dreiging | Impact | Risico | Mitigatie |
|---|---|---|---|---|
| | Gateway-firmware om root-toegang te krijgen tot het interne netwerk. | | | netwerksegmentatie (DMZ). |

## 2.2 Asset: GBS Server (Windows Server 2012)

*Locatie: Engineering Room Functie: Regelt HVAC en Koeling. Kwetsbaarheid: OS is End-of-Life (EoL).*

| STRIDE Categorie | Specifieke Dreiging | Impact | Risico | Mitigatie |
|---|---|---|---|---|
| **Tampering** | Exploitation van bekende kwetsbaarheden (bv. EternalBlue) omdat patches ontbreken. | Installatie van ransomware of backdoors. | **Kritiek** | **Direct vervangen** door Server 2022 of isoleren zonder internettoegang. |
| **Denial of Service** | Crashen van de HVAC-service door een buffer overflow aanval. | Uitval koeling -> Bederf voorraad (€12M schade). | **Hoog** | Host-based firewalling en strikte ACLs. |
| **Info Disclosure** | Uitlezen van geheugen of configuratiebestanden met passwords in plaintext. | Verkrijgen van domein-credentials. | **Medium** | Versleuteling van schijven en configs. |

## 2.3 Asset: PLCs (Siemens S7-1200) & HMIs

*Locatie: Factory Floor (Smeltlijn/Gietlijn) Functie: Aansturing fysiek proces.*

| STRIDE Categorie | Specifieke Dreiging | Impact | Risico | Mitigatie |
|---|---|---|---|---|
| **Spoofing** | Een rogue device in het netwerk stuurt | Ongeautoriseerde machine-acties. | **Hoog** | MAC-address filtering en 802.1X NAC. |

| STRIDE Categorie | Specifieke Dreiging | Impact | Risico | Mitigatie |
|---|---|---|---|---|
| | commandos naar de PLC (S7-protocol heeft vaak geen authenticatie). | | | |
| **Tampering** | Wijzigen van 'setpoints' (temperatuur/mengverhouding) via het HMI of engineering station. | Kwaliteitsverlies of fysieke schade. | **Hoog** | Integrity checks op PLC-code (Logic checksums). |
| **Repudiation** | Een operator of aanvaller wijzigt parameters, maar er zijn geen logs wie wat deed. | Onmogelijkheid tot forensisch onderzoek. | **Medium** | Centralized Logging (SIEM) voor OT-acties. |

## 2.4 Asset: Datacenter (FileShares & Auth Server)

*Locatie: Datacenter Functie: Centrale opslag en identiteitsbeheer.*

| STRIDE Categorie | Specifieke Dreiging | Impact | Risico | Mitigatie |
|---|---|---|---|---|
| **Elevation of Privilege** | Lateral movement vanaf een geïnfecteerde kantoorlaptop (via phishing) naar de Domain Controller. | Volledige overname van het domein (Golden Ticket). | **Kritiek** | Tiering model voor beheerders (Tier 0/1/2). |
| **Info Disclosure** | Ransomware exfiltreert data van de B-Disk (recepten) en M-Disk (persoonsgegevens). | Datalek (AVG boete) en verlies concurrentiepositie. | **Kritiek** | Data Loss Prevention (DLP) en encryptie at rest. |

## 3. Attack Tree Analyse

Hieronder is een waarschijnlijk aanvalspad uitgewerkt: **"Doel: Sabotage van de Productielijn"**

1. **Stap 1: Initial Access (Internet -> Office)**
    - *Methode:* Phishing e-mail naar een operator of administratief medewerker.
    - *Resultaat:* Malware op een kantoorlaptop.
2. **Stap 2: Lateral Movement (Office -> Datacenter -> Engineering)**
    - *Methode:* Scannen van het netwerk. Omdat er geen strikte segmentatie is tussen Office en Engineering VLANs, vindt de malware de **Gateway** of **GBS Server**.
    - *Kwetsbaarheid:* GBS Server (Win 2012) is vatbaar voor SMB-exploit.
3. **Stap 3: Execution (Engineering -> Factory)**
    - *Methode:* Vanuit de gehackte GBS Server wordt verbinding gemaakt met de PLCs (S7-1200).
    - *Actie:* Sturen van 'Stop' commando of overschrijven van temperatuurwaarden.

## 4. Prioriteitenlijst voor Mitigatie (Top 5)

Op basis van de threat modeling zijn dit de meest urgente acties:

1. **Netwerksegmentatie (Purdue Model):** Plaats een firewall tussen het kantoornetwerk (Enterprise) en het productienetwerk (Factory/Engineering). Blokkeer al het verkeer behalve strikt noodzakelijke datastromen.
2. **Gateway Hardening:** Schakel de huidige toegang via de Gateway uit totdat MFA en VPN zijn ingericht. Dit is het grootste gat in de verdediging.
3. **GBS Server Upgrade:** De Windows 2012 server is een tijdbom. Upgrade of isoleer deze volledig van het internet en kantoornetwerk.
4. **MFA Implementatie:** Voor alle remote access en beheerdersaccounts.
5. **OT Monitoring:** Implementeer een IDS (Intrusion Detection System) die specifiek OT-protocollen (S7comm, Modbus) begrijpt om afwijkend gedrag te detecteren.

# 3.2 Attack Surface Analysis

## 1. Attack Surface Analysis: Billy Bonka B.V.

Dit document beschrijft de **Attack Surface** (het aanvalsoppervlak) van Billy Bonka B.V. Dit omvat alle punten waar een ongeautoriseerde gebruiker (aanvaller) data kan invoeren, onttrekken of systemen kan manipuleren.

### 1.1 Digital Attack Surface (Extern)

Dit zijn de toegangspunten vanaf het internet die direct zichtbaar of bereikbaar zijn voor aanvallers.

| Entry Point | Beschrijving & Kwetsbaarheid | Risico Score |
|---|---|---|
| **Remote Gateway** | De gateway in de Engineering Room verbindt de OT-omgeving direct met de buitenwereld voor leverancierssupport. **Kwetsbaarheid:** Geen MFA, vermoedelijk zwakke authenticatie, geen IP-whitelisting. | **Kritiek (9/10)** |
| **Kantoor E-mail** | Medewerkers ontvangen e-mails met bijlagen en links. **Kwetsbaarheid:** Geen geavanceerde e-mail filtering, personeel is niet getraind in phishing, laptops hebben lokale admin-rechten. | **Hoog (8/10)** |
| **Wi-Fi Netwerk** | Het draadloze netwerk in de kantoorpanden. **Kwetsbaarheid:** Indien het Wi-Fi signaal buiten het pand reikt, kan een aanvaller proberen in te breken (bv. via zwakke WPA2 PSK) en direct op het interne netwerk komen. | **Medium (6/10)** |
| **VPN (Indien aanwezig)** | Er wordt gesproken over thuiswerken. | **Hoog (7/10)** |

| Entry Point | Beschrijving & Kwetsbaarheid | Risico Score |
|---|---|---|
| | **Kwetsbaarheid:** Zonder MFA en endpoint checks kunnen gestolen credentials direct leiden tot netwerktoegang. | |

## 1.2 Digital Attack Surface (Intern / Lateral)

Zodra een aanvaller binnen is (bv. via een phishing mail op een laptop), hoe groot is het speelveld dan?

| Asset | Exposure | Beschrijving |
|---|---|---|
| **Flat Network** | **Volledig** | Er is geen effectieve segmentatie (VLAN/Firewall) tussen het Kantoor (IT) en de Fabriek (OT). Een geïnfecteerde laptop kan pingen naar de PLC's. |
| **GBS Server** | **Legacy OS** | Draait op **Windows Server 2012** (End-of-Life). Dit OS heeft honderden bekende kwetsbaarheden (CVE's) waarvoor geen patches meer zijn. Het fungeert als een makkelijk doelwit voor lateral movement. |
| **File Shares** | **SMB Protocol** | De B-Disk en M-Disk zijn toegankelijk via SMB. Als SMBv1 nog aanstaat (voor legacy apparatuur), is dit kwetsbaar voor ransomware wormen. |
| **OT Protocollen** | **Unencrypted** | De communicatie tussen Engineering Stations en PLCs (S7comm) is onversleuteld en ongeauthenticeerd. Iedereen op het netwerk kan commando's sturen. |

## 1.3 Human Attack Surface (Social Engineering)

De menselijke factor is bij Billy Bonka een aanzienlijk deel van het aanvalsoppervlak.

- **Gedeelde Accounts:** Operators gebruiken generieke accounts. Als één wachtwoord lekt, heeft de aanvaller toegang tot alle HMI's.
- **"Helpful" Culture:** IT is geneigd om controles uit te schakelen ("MFA is te lastig"). Een aanvaller die zich voordoet als "Spoedhulp van Microsoft" maakt grote kans.
- **Gebrek aan Awareness:** Uit interviews blijkt dat termen als 'phishing' of 'ransomware' worden weggewuifd.

## 1.4 Physical Attack Surface

Fysieke toegang tot apparatuur kan beveiligingslagen omzeilen.

- **Engineering Room:** Hier staan de kritieke GBS en Engineering werkstations. Als deze ruimte niet strikt gesloten is (bv. open deur beleid vanuit de hal), kan een kwaadwillende insider of bezoeker een USB-stick met malware plaatsen ("USB drop attack").
- **Netwerkpoorten:** Ongebruikte netwerkpoorten in vergaderzalen of de kantine die live verbonden zijn met het interne netwerk.
- **Serverruimte (Datacenter):** Bevat de fysieke NAS en Servers. Toegang moet strikt gelogd zijn.

## 1.5 Supply Chain Attack Surface

Afhankelijkheden van derde partijen die toegang hebben tot het netwerk of software leveren.

- **Leverancier HVAC/Koeling:** Heeft permanente toegang via de Gateway. Als de leverancier gehackt wordt, is Billy Bonka direct gecompromitteerd.
- **Software Updates:** Updates voor het GBS of PLC-firmware worden vermoedelijk zonder verificatie (signing check) geïnstalleerd.

## 1.6 Attack Surface Reduction (ASR) Plan

Om het aanvalsoppervlak te verkleinen, adviseren wij de volgende **ASR-regels**:

1. **Reduce Entry Points:**

    - Sluit de permanente Gateway-verbinding. Vervang dit door een "On-Demand" VPN die alleen open gaat na goedkeuring van de interne IT-manager.
    - Blokkeer internettoegang voor de GBS Server en PLCs (zij hebben geen internet nodig voor hun taak).

2. **Harden Internal Targets:**

    - Upgrade Windows Server 2012 naar 2022 (verwijdert duizenden CVE's van het bord).
    - Schakel ongebruikte services en poorten uit op alle servers.

3. **Segmentatie:**

    - Implementeer het **Purdue Model**. Zorg dat Kantoor (Laag 4) *niet* direct kan praten met PLCs (Laag 1). Dit verkleint het 'zichtbare' oppervlak vanuit het kantoor enorm.

4. **Human Firewall:**

    - Start een verplicht awareness programma.
    - Dwing unieke accounts af; elimineer gedeelde wachtwoorden.

# 3.3 Risk Analysis

Om te bepalen welke risico's voor Billy Bonka het meest urgent zijn, is een risicoanalyse uitgevoerd op basis van de formule:

**Risico = Impact × Kans**

Beide factoren worden gewaardeerd op een schaal van **1 (laag)** tot **5 (zeer hoog)**.

De impact beschrijft hoe zwaar een verstoring is voor de organisatie, terwijl de kans aangeeft hoe waarschijnlijk het is dat het risico zich voordoet. Door deze waarden te vermenigvuldigen ontstaat een **risicoscore tussen 1 en 25**, waarbij een hogere score meer prioriteit vereist.

## 1. Ransomware die IT én OT platlegt

**Impact: 5 (zeer hoog)**
Een ransomware-infectie kan de volledige productie stoppen. Zonder toegang tot PLC's, koeling, fileshares en Active Directory ligt de fabriek binnen minuten stil. De schade betreft omzetverlies, productverlies (doordat chocolade bederft) en reputatieschade.
**Kans: 4 (hoog)**
De organisatie heeft geen MFA, geen patchbeleid, en medewerkers zijn niet bewust van phishing. Hierdoor is ransomware waarschijnlijk.
**Risicoscore = 5 × 4 = 20 → *Zeer hoog risico***

## 2. Uitval van HVAC of koeling

**Impact: 5 (zeer hoog)**
De temperatuur van grondstoffen en chocolade is cruciaal. Een paar uur zonder koeling kan leiden tot bederf van voorraad ter waarde van duizenden euro's.
**Kans: 3 (middel)**
De koeling wordt extern gemonitord, maar de GBS-server draait op verouderde Windows Server 2012 en er is geen redundantie.
**Risicoscore = 5 × 3 = 15 → *Hoog risico***

## 3. Misbruik van externe toegang (Gateway / leverancier)

**Impact: 4 (hoog)**
Als een aanvaller via de Gateway binnenkomt, kan die direct bij het engineeringstation en daarmee de PLC's. Dit beïnvloedt de productie direct.
**Kans: 3 (middel)**
Geen MFA, geen logging en oude netwerkbeveiliging maken dit reëel.
**Risicoscore = 4 × 3 = 12 → *Hoog risico***

## 4. Ongepatchte systemen (Windows XP, Server 2012)

**Impact: 4 (hoog)**
Een kwetsbaarheid in deze systemen kan leiden tot besmetting, datalekken of sabotage van OT-processen.
**Kans: 4 (hoog)**
De IT-medewerker geeft aan nauwelijks te patchen, waardoor bekende exploits openstaan.
**Risicoscore = 4 × 4 = 16 → *Zeer hoog risico***

## 5. Phishing en menselijke fouten

**Impact: 3 (middel)**
Een phishingaanval kan leiden tot datalekken of accountmisbruik. Dit raakt vooral IT-processen zoals e-mail en administratie.
**Kans: 4 (hoog)**
Medewerkers herkennen phishing niet, en er is geen training. Ook worden waarschuwingen weg geklikt.
**Risicoscore = 3 × 4 = 12 → *Hoog risico***

## 6. Verlies van PLC-configuraties

**Impact: 4 (hoog)**
Zonder back-ups moeten PLC-programma's opnieuw worden geschreven, wat dagen tot weken kost.
**Kans: 2 (laag–middel)**
Er zijn back-ups, maar deze worden niet getest → risico dat ze corrupt of onvolledig zijn.
**Risicoscore = 4 × 2 = 8 → *Middel risico***

## 7. Gedeelde accounts en zwak wachtwoordbeheer

**Impact: 3 (middel)**
Fouten en misbruik zijn moeilijk te traceren. Dit kan leiden tot sabotage of ongeautoriseerde wijzigingen, vooral in de fabriek.
**Kans: 4 (hoog)**
Komt nu structureel voor: operators delen wachtwoorden en de directeur geeft zijn wachtwoorden aan zijn assistente.
**Risicoscore = 3 × 4 = 12 → *Hoog risico***

| Risico | Impact | Kans | Score |
|---|---|---|---|
| Ransomware | 5 | 4 | **20** |
| Ongepatchte systemen | 4 | 4 | **16** |
| Uitval koeling/HVAC | 5 | 3 | **15** |
| Externe toegang misbruik | 4 | 3 | **12** |
| Phishing | 3 | 4 | **12** |
| Gedeelde accounts | 3 | 4 | **12** |
| Verlies PLC-configuraties | 4 | 2 | **8** |

# 4. Secure Development & Weerbaarheid

Om de digitale systemen van Billy Bonka weerbaarder te maken tegen cyberaanvallen, is het belangrijk dat niet alleen de infrastructuur wordt verbeterd, maar dat ook het ontwikkel- en beheerproces professioneler en veiliger wordt ingericht. In de organisatie worden systemen onderhouden door interne IT-medewerkers en externe leveranciers. Hoewel Billy Bonka zelf weinig software ontwikkelt, worden er wél regelmatig aanpassingen gedaan aan PLC-programma's, configuraties van HMI-panelen en updates van beheertools. Daarom is het noodzakelijk dat ook deze processen voldoen aan principes van Secure Development.

Bij Secure Development gaat het niet alleen om veilig programmeren, maar vooral om een gecontroleerde, herhaalbare werkwijze waarmee fouten worden voorkomen en kwetsbaarheden tijdig worden ontdekt. Voor Billy Bonka betekent dit dat er een veilig proces moet komen rondom wijzigingen in de OT-omgeving (zoals de PLC's), updates aan applicaties in de IT-omgeving en de manier waarop leveranciers toegang krijgen tot systemen.

## 4.1 Hoe de organisatie veilige softwareontwikkeling kan borgen

### 1. Een formeel change management-proces

Elke wijziging aan PLC's, configuraties of applicaties moet vooraf worden geregistreerd, goedgekeurd en getest. Nu worden wijzigingen soms direct in de fabriek toegepast zonder documentatie, waardoor fouten moeilijk te achterhalen zijn. Een change-proces voorkomt dat verkeerde instellingen of kwetsbare firmware worden geïnstalleerd.

## 2. Versiebeheer voor PLC-programma's en configuraties

PLC-programma's moeten worden opgeslagen in een centrale repository, bijvoorbeeld op de NAS of een Git-achtige omgeving. Hierdoor kan altijd worden teruggekeerd naar een vorige versie als een wijziging problemen veroorzaakt.

## 3. Testomgeving (OT-sandbox)

Een veilige testomgeving maakt het mogelijk om PLC-wijzigingen te testen zonder risico voor de productie. Dit hoeft geen volledige productielijn te zijn; een simulatie- of test-PLC is al voldoende om fouten vroegtijdig te ontdekken.

## 4. Leveranciers moeten aan security-eisen voldoen

Omdat leveranciers toegang hebben tot het engineeringstation en de gateway, moeten zij voldoen aan beveiligingseisen zoals:

- MFA verplicht (Wachtwoord + Druppel)
- Unieke accounts (geen gedeelde logins)
- Logging van alle acties
- Geen verbindingen via privé-laptops
- Gecontroleerde remote access via een jump server

## 5. Secure Coding en Secure Configuratie

Voor interne IT-systemen moeten vaste richtlijnen worden opgesteld:

- geen hard-coded wachtwoorden in scripts;
- standaard configuraties vervangen door hardened configuraties;
- veilige protocollen gebruiken (SSH, SFTP, TLS 1.2+);
- input-validatie bij webapplicaties of formulieren;
- periodieke code-reviews voor interne tools of scripts.

## 6. Regelmatige security-scans en penetratietests

Naast technische inventarisatie moeten systemen jaarlijks worden getest op kwetsbaarheden. Denk aan:

- OT-penetratietest uitgevoerd door gespecialiseerde OT-securitypartij
- IT-scan op servers, werkplekken en netwerk;
- Testen van rechten, configuraties en updates.

## 7. Awareness-training voor ontwikkelaars en beheerders

Beheerders moeten getraind worden in:

- veilige configuratie
- patchbeheer

- veilige wachtwoorden
- incident detectie
- veilige remote access

Zo wordt niet alleen techniek, maar ook gedrag veiliger.

# 4.2 Interviewplan voor ontwikkelaars en beheerders

Om de weerbaarheid van digitale systemen te kunnen evalueren, moet er een gestructureerd interviewplan zijn. De interviews worden afgenomen onder interne IT-beheerders, leveranciers en eventuele engineers die PLC's of applicaties aanpassen. Het doel is inzicht krijgen in werkwijze, risico's, kennisniveau en mogelijke verbeterpunten.

## Doel van het interviewplan

- Controleren hoe wijzigingen worden gemaakt
- Begrijpen welke beveiligingsmaatregelen men toepast
- Identificeren van risico's in ontwikkel- en beheerprocessen
- Vaststellen welke kennis en vaardigheden nog ontbreken
- In kaart brengen hoe leveranciers toegang krijgen en hoe veilig dit gebeurt

## 2.1 Interviewplan

### 1. Proces & Change Management

**Vraag:** Hoe wordt een wijziging aan een PLC-programma, server of applicatie voorbereid en vastgelegd?
**Doel:** Begrijpen of er een formele procedure bestaat of dat het ad-hoc gebeurt.

**Vraag:** Hoe worden wijzigingen getest voordat ze live gaan?
**Doel:** Vaststellen of er een testomgeving is en hoe volwassen deze gebruikt wordt.

### 2. Beveiliging & Toegang

**Vraag:** Op welke manier krijgen beheerders en leveranciers toegang tot systemen?
**Doel:** Evalueren van veilige toegang, MFA en logging.

**Vraag:** Worden accounts gedeeld of heeft iedereen een eigen account?
**Doel:** Identificeren van risico's rond accountability en misbruik.

**Vraag:** Hoe worden wachtwoorden beheerd?
**Doel:** Controleren of er een password manager, beleid of MFA is.

### 3. Secure Development & Configuratie

**Vraag:** Hoe wordt documentatie bijgehouden van PLC-configuraties, scripts of applicaties?
**Doel:** Vaststellen van versiebeheer en documentatiekwaliteit.

**Vraag:** Hoe wordt gecontroleerd of configuraties veilig zijn?
**Doel:** Begrijpen of men bekend is met security-standaarden of hardening.

## 4. Patching & Updates

**Vraag:** Hoe vaak worden systemen gepatcht en wie is hiervoor verantwoordelijk?
**Doel:** Vaststellen of er achterstallig onderhoud is.

**Vraag:** Wordt er getest of patches problemen veroorzaken in de OT-omgeving?
**Doel:** In kaart brengen van risico's op uitval door updates

## 5. Monitoring & Incident Response

**Vraag:** Hoe signaleren jullie dat er verdachte activiteiten plaatsvinden?
**Doel:** Beoordelen of logging en monitoring aanwezig is.

**Vraag:** Hoe wordt gehandeld bij een incident?
**Doel:** Controleren of er een incident response procedure bestaat.

## 6. Kennis & Weerbaarheid

**Vraag:** Hoe wordt er omgegaan met security-training of awareness-programma's en pas je dit dagelijks toe?
**Doel:** Vaststellen van kennisniveau.

**Vraag:** Wat vinden jullie het grootste beveiligingsrisico binnen jullie werk?
**Doel:** Inzicht krijgen in ervaringen en zwakke plekken die formeel misschien nog niet waren opgevallen.